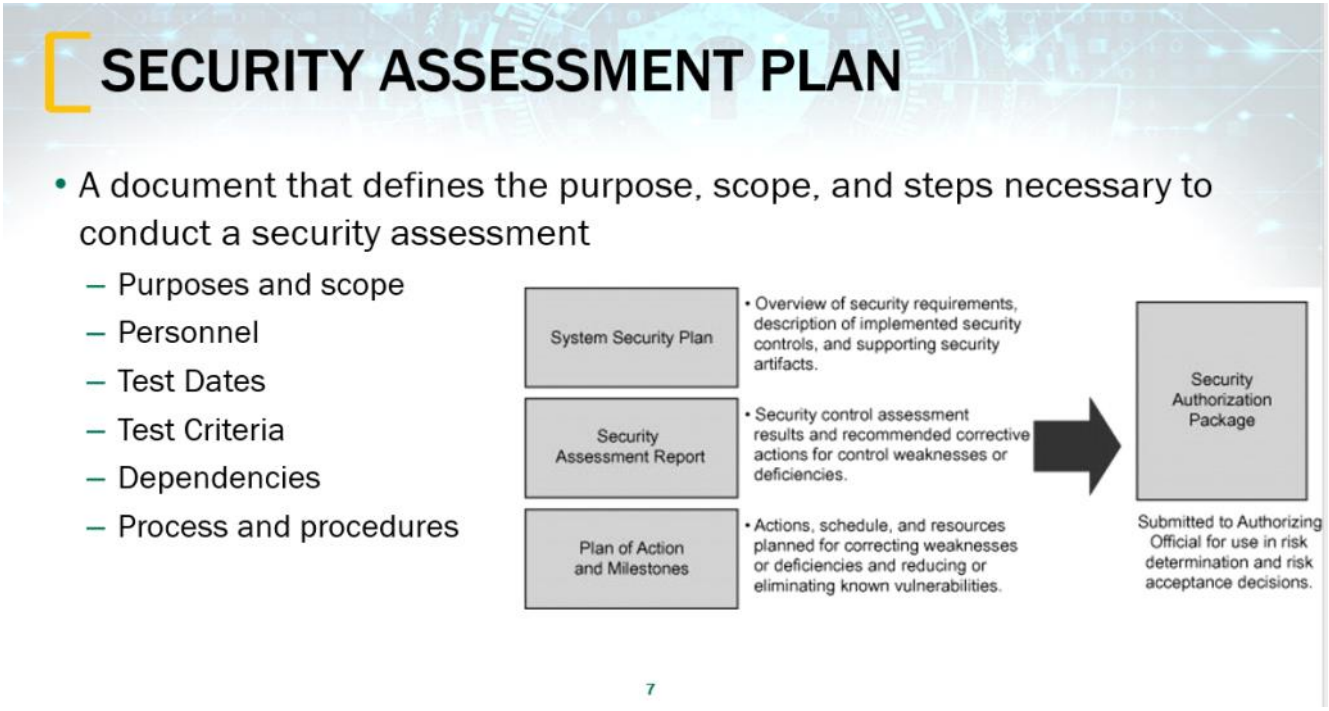
Saturday, February 27, 2021 1:58 PM

Domain 6: Security Assessment and Testing

- **Design and validate assessment, test, and audit strategies**
  - Information Security Assessment
    - **An information security assessment is a process of determining how effectively the entity being evaluated meets specific security criteria (assurance).**
    - The objective of an assessment is to substantiate strengths and to identify weaknesses and failures.
    - The target of the assessment is known as the assessment object.
    - The security assessment process is often referred to as T&E (Testing and Examination).
    - Internal
      - Internal testing and assessment design and validation are intended to "work from the internal network and assume the identity of a trusted insider or an attacker who has penetrated the perimeter defenses."
      - Internal testing may include the assessor attempting to gain access that is additional to what is provisioned to network or system resources through privilege escalation
    - External
      - "offering the ability to view the environment's security posture as it appears outside the security perimeter—usually as seen from the Internet—to reveal vulnerabilities that could be exploited by an external attacker."
- External tests are often done in a blind format where the assessors only have information that is available to the public.
- The internal team or security staff may be forewarned of the test, or the test could be rendered without notice and therefore, be double-blind where the internal team doesn't know about the impending test.
- Development of external testing strategies can be driven by regulatory, legal, or jurisdictional regimes
- Third-Party
  - Organizational alignment of business needs and requirements should be considered before engaging third-party assessor services
  - Analysis of business needs, requirements, and risks leads to developing clear and concise operational boundaries for third-party assessment.
  - Nondisclosure agreements should be executed before any work by a third-party assessor commences
- **Proper planning is critical to a successful security assessment**
- **Developing a Security Assessment Policy**
  - Organizations should develop an information security assessment policy to provide direction and guidance for their security assessments. This policy should identify security assessment requirements, and hold accountable those individuals responsible for ensuring that assessments comply with the requirements.
  - It should address:
    - Organizational requirements with which assessments must comply
    - Appropriate roles and responsibilities (at a minimum, for those individuals approving and executing assessments) Adherence to established methodology
    - Assessment frequency
    - Documentation requirements, such as assessment plans and assessment results.
- **Different between test & an assessment**
  - A test is a comparison between the properties of the system and some predetermine standardized configuration. An assessment is a series of related tests.
- NIST SP 800-53r4 delineates several steps that an assessor should consider when developing an assessment plan for information security testing. The steps are as follows:
  - Determine the type of security control assessment.
  - Determine the security controls and enhancements to be included.
  - Select the appropriate assessment procedures to be used.
  - Tailor the selected assessment procedures to match the organization's operating environment.
  - Develop additional assessment procedures to address enhancements.
  - Optimize assessment procedures to reduce duplication and increase cost-effectiveness.
  - Finalize assessment plan and obtain approvals necessary for the execution
- **The assessment plan should answer these basic questions:**
  - What is the scope of the assessment?
  - Who is authorized to conduct the assessment?
  - What are the assessment's logistics?
  - How should sensitive data be handled?
  - What should occur in the event of an incident?



- The skills possessed by an assessment team should be balanced to provide a well-rounded view of the organization's security posture
- Assessors conduct examinations and tests using technical methods and techniques, such as those described in this guide

- The role of the Systems Engineer and Security professional plays an important role in security assessment and testing
  - Create or Assess test and evaluation strategies
    - Across the lifecycle in support of initiation acquisition/development, Operations, Maintenance, and Disposal.
  - Recommend test and evaluation approaches
    - Have a suite of approaches to include observation, Samples, Scans, independent internal tester, qualified external testers
    - Design a Security test template and test process
  - Evaluate tests plan and procedures
    - Initial security test template as part of the test process
    - Review/Approve proposed security test plans and procedures
  - Create or assess the general process for reporting findings and remediating non-compliance
    - Promote validation of findings, appropriate reporting and plan of action, and milestone to remediate non-compliance
    - Ensure re-examination to close finding
- Prepare the security methodology, roles, and responsibilities, dependencies, scope of testing, Assumptions and test completion criteria, test strategy, Test expectations..etc
- The Role of Assessment Team & Software Verification
  - Updates to test and evaluation strategy
  - Ensure test and Evaluation processes are consistent with the overall strategy.
  - Ensure user's capability-based operational requirements are being met by the system
  - Where third parties are involved in development or operations, the contract should address security testing activities.
- Software Verification
  - Software functional testing
    - Test Functionality of Application
  - Static and Dynamic Analysis
    - Static Analysis - Application is not running we manually revise the code.
    - Dynamic Analysis - Application is running and we are parallelly performing the Testing.
  - Code and Document Inspections
    - Review the code
  - Code Walkthroughs
    - High-level walkthrough of the code
- Assessment Vectors
  - **Internal assessment**
    - A security assessment conducted by internal organizational personnel, Due care.
      - e.g. Before deployment or integration
      - After a system update
      - Before compliance audit
      - In response to a vulnerability alert
  - **External Assessment**
    - A security assessment is performed by external or third-party personnel. Due Diligence. Provides more independence
      - e.g. Formal Compliance audit
      - Security control assessment before transferring software to a company
      - Hiring a company to verify security controls
      - Using outside professionals to conduct a security audit.
  - **Verification**
    - Met the documented requirements agreed, look for consistency, completeness, and correctness of the software and its supporting

documents
    - **Validation**
        - Validation is a matter of developing a "level of confidence" that the software or system meets all requirements and user expectations as documented. Met the user objectives UAT Team Testing
- Security Assessment Plan (SAP)
    - A document that defines the purpose, scope, and steps necessary to conduct a security assessment
        - Purpose & Scope
        - Personnel
        - Test Dates
        - Test Criteria
        - Dependencies
        - Process & Procedures
- Assessment Methodologies
    - Testing
        - Testing is the process of exercising objects under specified conditions to compare actual and expected behaviors.
        - **Testing is an active activity.**
            - Strength
                - Can provide a real-world picture of an organization's security posture
                - Can evolve and mimic current attacker techniques
    - Weakness
        - May not provide a comprehensive evaluation due to limitations of time, resources, or tester
        - May be intrusive
- Examination
    - Examination is the process of reviewing, inspecting, studying, and observing to facilitate understanding, comparing to standards or baselines, or obtaining evidence.
    - **Examination is a passive activity.**
        - Strength
            - May gain insight not otherwise available
            - A broad scope of coverage with limited resources
        - Weakness
            - May not provide assurance that the security controls are working as intended
- Rules of Engagement (ROE)
    - A rule of engagement (ROE) document details the parameters and expected assessor conduct of the assessment (exam/test).
    - Scope
        - Scope, assumptions, limitations, and risks
        - Logistics such as personnel, test schedule, test site, and equipment
        - Communications plan
        - Target system
        - Testing expectations and data handling requirements
        - Reporting
- Legal considerations
    - Legal considerations include authorization, liability, indemnification, nondisclosure, and privacy.

- **Conduct security control testing**
    - Vulnerability assessment
        - Systematic examination of an information system or product to determine the adequacy of security measures, identify security deficiencies, provide data from which to predict the effectiveness of proposed security measures, and confirm the adequacy of such measures after implementation.
        - **"Penetration testing and vulnerability assessments provide a snapshot of a system in a specific state at a specific time. The snapshot is limited to those portions of the system tested during the penetration attempt(s). Penetration testing and vulnerability assessments are not a substitute for risk assessment.**"
        - Describing Vulnerabilities
            - **Common Vulnerabilities and Exposures (CVE)**:- Provides a naming system for describing security vulnerabilities. Used by the tools to verify the signature and vulnerability. Ex: http://cve.mitre.org/ - Refer to the website **(Identifying particular Vulnerabilities we have CVE)**
            - **Common Vulnerability Scoring System (CVSS)**:- Provides a standardized scoring system for describing the severity of security vulnerabilities. **Scap testing method**,**(Giving Scoring system we have CVSS)**
            - **Common Configuration Enumeration (CCE)**:- Provides a naming system for system configuration issues. It's not a vulnerability, but the configuration issues could result in vulnerability. **(configuration rumination)**
        - Application Security Verification Standard (ASVS)
            - As per OWASP vulnerability. The Open Web Application Security Project (OWASP) is a 501(c)(3) worldwide not-for-profit charitable organization focused on improving the security of software.
            - It's a community effort to establish a framework of security requirements and controls that focus on normalizing the functional and non-functional security controls required when designing, developing, and testing modern applications
            - ASVS has four levels, the application is assessed based on the level.
                - Level 1 - is meant for all software
                - Level 2 - is meant for an application that contains sensitive data
                - Level 3 - is meant for most critical applications - applications that process high-value transactions or contain sensitive medical data.
        - Security Content Automation Protocol (SCAP)
            - **SCAP The Security Content Automation Protocol (SCAP) is a method for using specific standards to enable automated vulnerability management, measurement, and policy compliance evaluation of systems deployed in an organization, including e.g., FISMA compliance.**

        - SCAP used to facilitate the different types of vulnerability framework

- Logs
    - Records of the events occurring within an organization's system and networks.
    - Composed of log entries
    - **Each entry contains information related to a specific event that has occurred within a system or network.**
    - **Log analysis is often reactive in nature, without sound processes for analyzing logs, the value of logs is significantly reduced.**
    - Log Management
        - **Nature of LMS is reactive.** Records of the events occurring within an organization's systems and networks. Composed of log entries - Each entry contains the information related to a specific event that has occurred within a system or network.
        - It's the process of **Generating, Transmitting, Storing, Analyzing, Disposing of computer security log data.**
        - Ensuring that computer security records are stored in sufficient detail for an appropriate period.
    - Common Security-Related OS Data
        - **System Events** Record application activities, system errors
        - **Audit Records** User attempting the wrong password tries to access the folder
        - Client requests and server responses
        - Account information such as successful and failed authentication attempts
        - Usage information such as the number of transactions occurring in a certain period.
        - Signification operational actions such as application startup and shutdown, application failures, and major application configuration changes
    - Protecting Logs
        - Logs are for establishing non-repudiation and accountability - Primary concern is **Confidentiality and Integrity**.
        - **Breaches:** Logs need to be protected from Confidentiality and Integrity breaches
        - Logs secured improperly in storage or transit might be susceptible.
    - Availability of Logs
        - Organization also need to protect the availability of their logs
            - Backup and offsite storage
            - Number of days online and how quickly offline data can be restored.
        - Many logs have a maximum size
            - Circular Overwrite - Should overwrite with new logs
            - Clipping - Perform on the stored logs **(Define the threshold once pass threshold passes send log)**
            - Audit Server -
            - Log Aggregator
    - Key Practices
        - Prioritize log management appropriately
        - Establish policies and procedures for log management
        - Create and maintain a secure log management infrastructure
        - Provide adequate support.

Preventing Log Tampering

Log files are often among the first artifacts that attackers will use to attempt to hide their actions. Knowing this, it is up to us as security professionals to do what we can to make it infeasible, or at least very difficult, for attackers to successfully tamper with our log files. The following are the top five steps we can take to raise the bar for the bad folks:

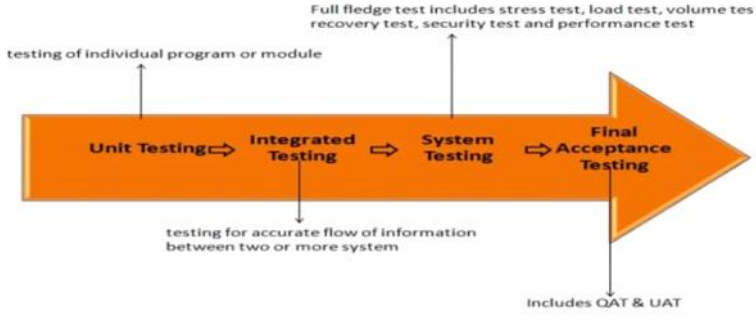
- Remote logging When attackers compromise a device, they often gain sufficient privileges to modify or erase the log files on that device. Putting the log files on a separate box will require the attackers to target that box too, which at the very least buys you some time to notice the intrusion.
- Simplex communication Some high-security environments use one-way (or simplex) communications between the reporting devices and the central log repository. This is easily accomplished by severing the "receive" pairs on an Ethernet cable. The term *data diode* is sometimes used to refer to this approach to physically ensuring a one-way path.
- Replication It is never a good idea to keep a single copy of such an important resource as the consolidated log entries. By making multiple copies and keeping them in different locations, you make it harder for attackers to alter the log files, particularly if at least one of the locations is not accessible from the network (e.g., a removable device).
- Write-once media If one of the locations to which you back up your log files can be written to only once, you make it impossible for attackers to tamper with that copy of the data. Of course, they can still try to physically steal the media, but now you force them to move into the physical domain, which many attackers (particularly ones overseas) will not do.
- Cryptographic hash chaining A powerful technique for ensuring events that are modified or deleted are easily noticed is to use cryptographic hash chaining. In this technique, each event is appended the cryptographic hash (e.g., SHA-256) of the preceding event. This creates a chain that can attest to the completeness and the integrity of every event in it.

- **Synthetic Performance Monitoring**
  - **Exam Point:- Question taking about SLA Testing what we agreed and what we testing**
  - Security Professionals also often become involved in the ongoing monitoring of websites for performance management, troubleshooting, and the identification of potential security issues.
  - Real User Monitoring (RUM)
    - **Passive monitoring** analyses actual network traffic sent to a website by capturing it as it travels over the network or reaches the server.
    - This provides real-world monitoring data that provides an administrator with insight into what is actually happening on a network.
    - RUM is an approach to Web monitoring **captures analyzes every transaction of every user** of the website or application.
    - Real user monitoring (RUM) is a passive monitoring technique that records user interaction with an application or system to ensure performance and proper application behavior.
    - RUM is often used as part of a pre-deployment process using the actual user interface.
    - **RUM is a variant of Passive monitoring where the monitoring tool reassembles the activity of the individual users to track their interactions with the websites**
    - It's good for troubleshooting.

- Synthetic Monitoring - Active monitoring
  - Synthetic Monitoring (or active monitoring) performs artificial transactions against a website to assess performance.
  - This may be as simple as requesting a webpage from a site to determine the response time, or it may execute a complex script designed to identify the results of a transaction.
  - Example of Synthetic monitoring is Microsoft System Center Operations Manager software
  - **Synthetic monitoring uses simulated behavior**, but synthetic user monitoring is not a testing method. Similarly, passive monitoring monitors actual traffic.
  - Benefits
    - Monitor application availability
    - Know if the remote site is reachable
    - Understand performance impacts
    - Monitoring performance availability of SaaS applications
    - Baseline and analyze performance trends.
    - Complement RUM
- Code Security Review and Testing
  - Testing and code review should verify the use of the standards and best practices as evidenced in what is developed

- Security Code Review
  - Examination of source code to verify that the proper security controls are present and work as intended.
  - The Fagan inspection process includes defined entry and exit criteria for moving through each step of the process to discover flaws.
- Testing Techniques **(VERY IMP EXAM)**
  - Black-box testing vs. white-box testing:
    - In black-box testing, the tested system is used as a black box, i.e., no internal details of the system implementation are used.
    - Black Box Testing is a software testing method in which the internal structure/ design/ implementation of the item being tested is NOT known to the tester.
    - In contrast, white-box testing takes the internal system details (e.g., the source code) into account.
    - White Box Testing is a software testing method in which the internal structure/ design/ implementation of the item being tested is known to the tester.
    - **Gray box testing** is a combination of a white and black box.
  - Dynamic testing vs. static testing
    - Static testing is done in the verification stage whereas dynamic testing is done in the validation stage.
    - In static testing, code is being examined without being executed.
    - Traditionally, testing is understood as dynamic testing, i.e the system under test is executed and its behavior is observed.
    - In dynamic testing, code is being executed and tested without necessarily being examined.
    - In contrast, static testing techniques analyze a system without executing the system under test.
  - Manual testing vs. automated testing:
    - In manual testing, the test scenario is guided by a human,
    - In automated testing, the test scenario is executed by a specialized application.
- After code has been prepared and made ready for execution, the following methods may be utilized for additional testing:
  - **Manual or automated penetration testing:** Simulates an attacker sending data to the application and observes its behavior:
    - Benefits: Identification of a wide range of vulnerabilities in a deployed application
  - **Automated vulnerability scanners:** Test an application for the use of system components or configurations that are known to be insecure. For this, predefined attack patterns are executed as well as system fingerprints are analyzed:
    - Benefits: Detection of well-known vulnerabilities, i.e., detection of outdated frameworks and misconfigurations
  - **Fuzz testing tools:** Send random data, usually in larger chunks than expected by the application, to the input channels of an application to provoke a crashing of the application:
    - Benefits: Detection of application crashes (e.g., caused by buffer overflows) that might be security-critical
- Testing Method Considerations
  - When selecting a security testing method or tool, consider the following:
    - **Attack surface:** Different security testing methods find different vulnerability type **Environment which we need to test/Validate.**
- **Application type:** Different security testing methods behave differently when applied to different application types
- **Quality of results and usability:** Security testing techniques and tools differ in usability (e.g., fix recommendations) and quality (e.g., false positives rate)
- **Supported technologies:** Security testing tools usually only support a limited number of technologies (e.g., programming languages), and if a tool supports multiple technologies, it does not necessarily support all of them equally well
- **Performance and resource utilization:** Different tools and methods require different computing power or different manual efforts
- Security Throughout the Software Development Life Cycle
  - Fixing bugs and security vulnerabilities late in software development is usually more costly compared with fixing them as early as possible.
  - **During Planning and Design**
    - Architecture Security
      - A manual review of the product architecture to ensure that it fulfills the necessary security requirement.
    - Threat Modeling
      - A structured manual analysis of an application-specific business case or usage scenario; this analysis is guided by a set of precompiled security threats.
      - Prerequisites:
        - Business Case or Usage Scenario
      - Benefits
        - Identification of Threats
  - **During Application Development**
    - Static Source Code Analysis (SAST) and Manual Code Review
      - Prerequisite we need application Source code, able to detect insecure programming, misconfiguration, outdated library.
    - Static Binary Code Analysis and Manual Binary Review
      - Analysis of compiled application, which is hosted on complier and Binary in Nature, for finding Vulnerability with executing the application
      - E.g (IDA Pro) Secure Review veracode
  - **Executable in a Test Environment**
    - Manual or Automated Penetration Testing
    - **Automated vulnerability scanners**

        - detects well-known vulnerabilities (tool maintains the signature of known vulnerabilities) can't detect the zero-day attack
    - **Fuzz Testing Tools**
        - When you send larger data than expected behavior by the application, trying to identify buffer overflow attacks.
- System Operation & Maintenance
    - Operation
        - Configuration Testing
        - Authorization Testing
        - Passive Testing of system Behavior
    - Maintenance
        - Test that patches are applied
        - Follow a trail of authorization of changes
- Software Testing Tenets
    - Type of Testing
        - Unit testing
            - Does a particular piece of code properly perform the task it is intended to?
            - Testing focuses on the early examination of sub-program functionality and ensures that functionally not visible at the system level is examined by testing.
        - Integration testing
            - Does the application behave as expected when integrated and Communicating with other systems in the environment?
            - Testing focuses on the transfer of data and control across a program's internal and external interface. External interfaces a re those with other software (including operating system software), system hardware, and the users and can be described as communication links.
        - System testing
            - This ensures that the application provides the required functionality and that the application is trustworthy as deployed in regard to security, privacy, performance, recovery, and usability.
        - Comprehensive Code Testing program
            - With an emphasis throughout the software development lifecycle, can ensure that developed applications are deployed with minimal vulnerabilities.
        - Regression Testing
            - Provide assurance that a change has not created problems elsewhere in the software product.
            - The determination of the impact of a change is based on a review of the relevant documentation to identify the necessary regression tests to be run.
            - Regression analysis and testing are employed to provide assurance that a change has not created problems elsewhere in the software product.
            - Regression analysis is the determination of the impact of a change based on a review of the relevant documentation
        - Interface testing
            - Checks components are in sync
            - Data Transfer happens per design
            - Control passes correctly



Unit testing

- Tests program logic within a particular program or module
- Ensures that the internal operation of the program performs according to specification
- Uses a set of test cases that focus on the control structure of the procedural design

Interface or integration testing

- A hardware or software test that evaluates the connection of two or more components that pass information from one area to another

System testing

- A series of tests designed to ensure that modified programs, objects, database schema, etc., which collectively constitute a new or modified system, function properly

Final acceptance testing

- System testing that takes place during the implementation phase and applies the organization's QA methodology

- Definition-Based Testing
  - Definition-Based, also referred to as
    - Specification-Based Testing
    - Functional Testing
    - Black-Box Testing
  - Identifies test cases based on the definition of what the software product is intended to do
- Testing Software Changes
  - Changes occur frequently during software development
  - These changes are the result of
    - Debugging
    - New or Changed requirements
    - Modified Designs
- Test Results
  - Document procedures, data, and results in a manner permitting objective pass/fail decisions to be reached.
  - Determine Appropriate Validation Effort
    - Determine the specific validation effort necessary for each software change based on the
      - Type of Change
      - Development products affected
      - Impact those products have on the operation of the software
- Test coverage analysis
  - Test coverage analysis is used to evaluate the degree of testing provided.
  - Test coverage analysis refers to identifying how the testing performed relates to the total functionality of the application.
  - Test/code coverage analysis provides a means to determine how much software code was tested during an assessment
  - Coverage analysis provides a level of confidence in the software product that is evaluated.
  - There are four main types of coverage criteria.
    - **Branch coverage** ensures that each branch in a control statement has been executed.
    - **Condition coverage** requires each Boolean expression to be validated for both true and false conditions.
    - **Function coverage** makes sure that every function in the program is called
    - **Statement coverage** validates the execution of every statement in the program.
- Effectiveness Assessment Methods
  - An Organization should employ various methods to determine access control effectiveness
    - Vulnerability Assessment
    - Penetration Testing
    - Application Security Testing
  - **Vulnerability Assessment**
    - Vulnerability assessments and Penetration testing takes a security assessment to next level
      - Involves identifying, categorizing, and addressing known vulnerabilities
      - Instead of verifying security design and functionality, the focus is on known security flaws
    - Conducting Vulnerability Assessments
      - Create and/or update an accurate system inventory of hardware, software, and firmware
      - Discover and identify potential security vulnerabilities to the system inventory
      - Categorize any vulnerability findings based on the level of criticality
      - Perform a cost/benefit analysis to determine which vulnerabilities to mitigate, reduce or eliminate.
    - Based on the vulnerability assessment, create a Security Assessment Report (SAR)
      - Good SAR report is the one which is alien with Security Assessment Plan
      - A document that defines the approach, process, and result of a security assessment.
      - The goal of a Security Assessment Report (SAR)
        - Identifies the security risks discovered by the security assessment.
        - Defines the assets and result of the security assessment
        - Defines the assessment process and steps taken that produced the result.
      - Benefits of a SAR
        - Consumer confidence
        - Legal or regulatory compliance
        - Legal liability protection
        - Future opportunities
    - Assessment Results
      - Identify the exact automated (tools) and Manual (Procedures) tests that were used.
      - Include output and/or reports for each test executed.
      - Identify any technical difficulties that may affect the test results
      - Include a summary and the detailed results of all assessment findings
    - Vulnerability Testing
      - Initiate Vulnerability test template.
        - Schedule for non-interference.
        - Obtain Approval
        - Coordinate
      - Execute
        - Validate Findings
      - Report
        - Enter Validated findings into remediation.
        - Confirm Remediated findings are closed.
        - Obtain risk approval for findings remediated with compensating controls
    - **OpenVAS** is an open-source vulnerability scanning tool that will provide Susan with a report of the vulnerabilities that it can identify from a remote, network-based scan.
    - Nmap is an open-source port scanner. Both the Microsoft Baseline Security Analyzer (MBSA) and Nessus are closed-source tools,

although Nessus was originally open source.

- **Penetration Testing**

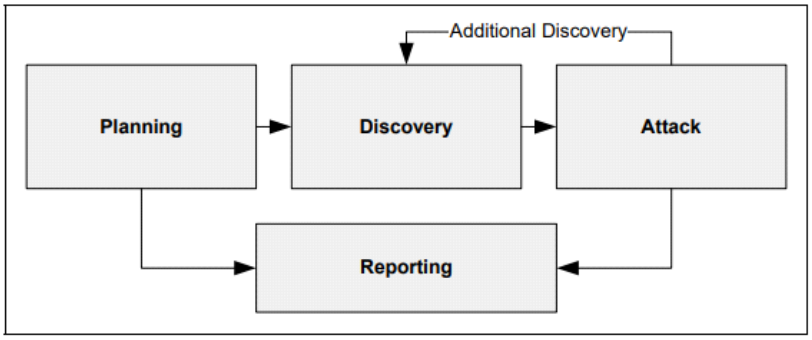


Figure 5-1. Four-Stage Penetration Testing Methodology

  - One means of evaluating the information security performance and effectiveness of an information security management system is through penetration testing.
  - Simulate an attack on a system or network to evaluate the risk profile of an environment.
  - The Key to successful and valuable penetration testing is clearly defined objectives, scope, stated goals, agreed-upon limitations, and acceptable activities
  - Penetration Test Steps **(EXAM IMP Sequence)**
    - Planning (Can be Overt/Covert)
      - Management Signed Off
    - Discovery
      - Information gathering and scanning.
      - Vulnerability Analysis
      - Which involves identifying and documenting information about the target
    - Attack
      - Gaining Access, Escalating Privileges
    - Reporting
      - It occurs during the same timeline as Planning, Discovery, Attack Phase
      - The reporting phase occurs simultaneously with the other three phases of the penetration test (see Figure 5-1). In the planning phase, the assessment plan—or ROE—is developed. In the discovery and attack phases, written logs are usually kept and periodic reports are made to system administrators and/or management. After the test, a report is generally developed to describe identified vulnerabilities, present a risk rating, and give guidance on how to mitigate the discovered weaknesses. Section 8 discusses post-testing activities such as reporting in more detail.
- Application Security Testing
  - Positive Testing / Use Case -- Systems works as expected business use cases
  - Negative Testing / Misuse case -- Opposite, Ensure that system can handle invalid use cases, whether accidental or deliberate

- Breach and Attack Simulation

  - Breach simulation automates the testing process and performs it continuously
  - The primary reason organizations would want to deploy BAS is because they want an answer to the fundamental question of whether their systems are secure
  - A breach simulation can simulate malware attacks on endpoints, data exfiltration, malware attacks and sophisticated APT attacks that move laterally through a network, targeting the most valuable assets.



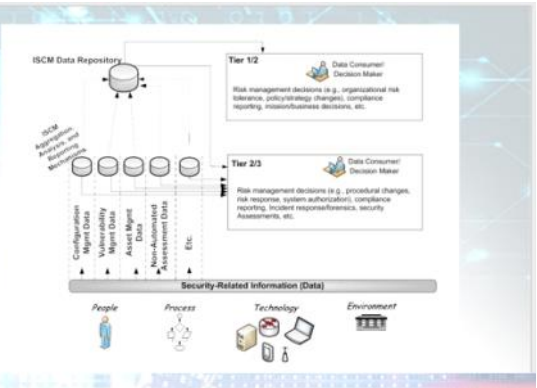
Protection of Test Data

- Guidelines include the following:
  - Verifying that the access control procedures utilized in production procedures are used in testing procedures.
  - Every time there is a need to use production data in testing environments, there is an individual and separate request for each use instance.
  - Whenever the testing is completed, the sensitive information should be completely erased.
  - Logs should trace the copying of production data to testing environments, and such logging should be used to form an audit trail

- **Collect security process data**
  - Information Security Continuous Monitoring (ISCM)
    - Information Security Continuous Monitoring is a holistic strategy to improve and address security.
    - This creates an environment where policies, the budget, and the vision for the company all include security as a cornerstone of the company's success.
    - ISCM is designed to align the fact of the organization including the people, the processes, and the technology in place.
    - There are several steps to implementing ISCM as outlined in NIST SP800-137
      - **Define an ISCM strategy** based on risk tolerance that maintains clear visibility into assets, awareness of vulnerabilities, up-to-date threat information, and mission/business impacts.
      - **Establish an ISCM program** determining metrics, status monitoring frequencies, control assessment frequencies, and an ISCM technical architecture.
      - **Implement an ISCM program** and collect the security-related information required for metrics, assessments, and reporting. Automate the collection, analysis, and reporting of data where possible.
      - **Analyze the data** collected and Report findings, determining the appropriate response. It may be necessary to collect additional information to clarify or supplement existing monitoring data.

ISCM

- Information security continuous monitoring (ISCM) is defined as maintaining ongoing awareness of information security, vulnerabilities, and threats to support organizational risk management decisions
- ISCM is designed to align fact of the organization including the people, the processes and the technology in place.
- Goal: Provide an organization with a repeatable and consistent methodology to assess ISCM programs that results in actionable recommendations to improve the ISCM program
- ISCM program assessment results include:
  - an indication of how well the assessed organization (entire organization, mission/business process, or system) meets the evaluation criteria
  - indications of ISCM program adequacy and consistency
  - recommendations for ISCM program design, implementation, operation, and governance that may need improvement





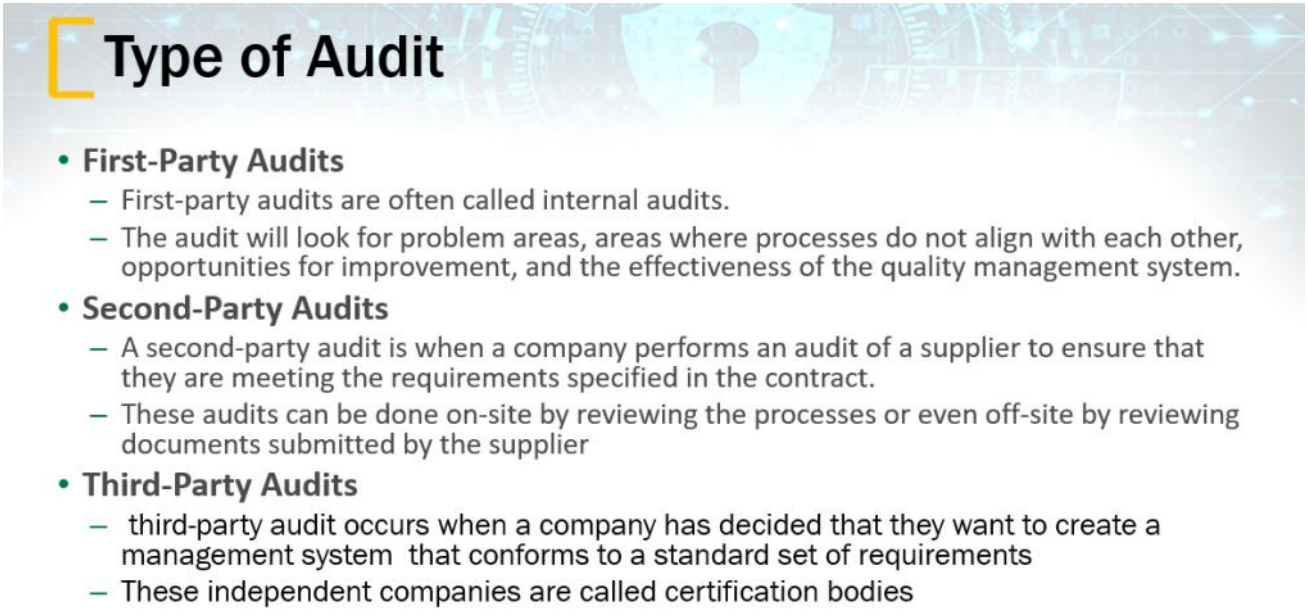
- **Respond to findings** with technical, management, and operational mitigating activities or acceptance, transference/sharing, or avoidance/rejection.
- **Review and Update** the monitoring program, adjusting the ISCM strategy and maturing measurement capabilities to increase visibility into assets and awareness of vulnerabilities, further enable data-driven control of the security of an organization's information infrastructure, and increase organizational resilience.
- Account management
  - Account management supports organization and mission/business functions by
    - Assigning account managers for information systems accounts.
    - Establishing conditions for group or role membership.

- Specifying authorized users of information systems.
- Requiring approval for authorizations, creating, enabling, modifying, disabling, and removing access.
- Monitoring use of information systems accounts.
- Notification to account manager when account access is no longer needed.
- Reviews account for compliance with account management requirements.

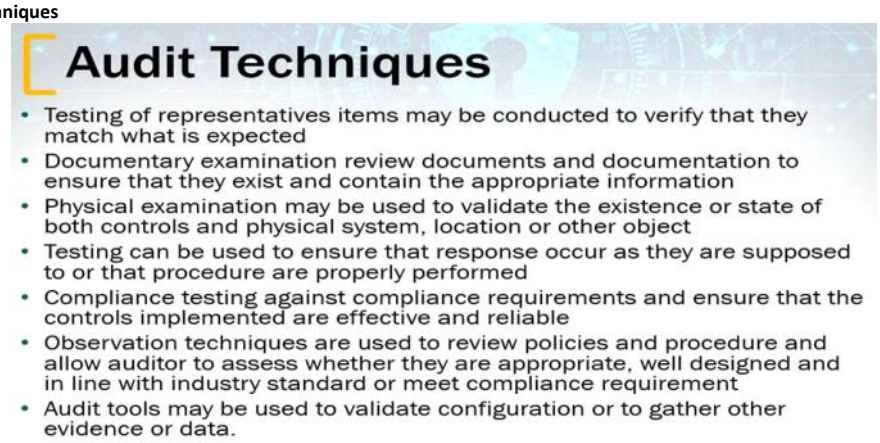
- Key performance and risk indicators
  - Key performance indicators (KPIs) are different from key risk indicators (KRIs).
  - **KPI** typically " Shed insights about risk events that have already affected the organization."
  - **KPIs** are essential to the management of emerging risk because they involve scrutinizing past activities to make corrections to future actions.
  - **KRI "**typically helps to better monitor Potential future shifts in risk conditions or new emerging risks so that management and boards can more proactively identify potential impacts on the organization's portfolio of risks."
  - **KRIs** are imperative to developing insights to recognizing risks that can impact achieving objectives
  - Management of KRIs begins with understanding root cause events, which may contain various activities and outcomes that give rise to intermediate events, which correspondingly lead to a risk event.
- Protection of Test Data
  - ISO 27002:2013 control 14.3.1 specifies the protection of test data.
  - Use of personally identifiable information (PII) should be avoided.
  - Verify access controls and procedures are in place.
  - When testing is completed, Sensitive information should be completely erased.
  - Logs should trace all copying of production data.
- Backup verification data
  - ISO 27002:2013 control item 12.3.1 specifies guidance for information backup.
  - A backup policy should be established to define the organization’s requirements for backup of information, software, and systems.
  - The backup policy should define the retention and protection requirements.
  - Adequate backup facilities should be provided to ensure that all essential information and software can be recovered following a disaster or media failure.
  - The backup plan should be based upon the business needs and corresponding policy, and it should have supporting documentation that provides procedures for proper restoration of data.
  - Backup frequency should be informed by business needs and description of restore point objectives.
- Training and Awareness
  - NIST SP 800-50 states, “The most significant difference between training and awareness is that **training seeks to teach skills, which allow a person to perform a specific function, while awareness seeks to focus an individual’s attention on an issue or set of issue**s.”
- Disaster Recovery (DR) and Business Continuity (BC)
  - Disaster recovery (DR) is a component of business continuity (BC).
  - DR is designed for the technical recovery of systems during a disaster.
  - BC addresses all elements of business resiliency during a disaster, both technical and non-technical.
  - Testing the effectiveness of the business continuity and disaster recovery (BCDR) planning is imperative to have an assurance of the continuance of the business.

- **Analyze test output and generate a report**
  - Produce Actionable Intelligence
    - Operational Metrics
      - Operational metrics drive vulnerability, threat, and risk management operations and control decisions
    - Key Performance Indicators
      - Key performance indicators inform management
    - Business Intelligence
      - Business intelligence supports alignment and long-term planning

- **Conduct or Facilitate Security Audits**
  - **Audit is Administrator detective control & it's all about reasonable assurance.**
  - An audit examination provides independent assurance based on evidence (examination) and testing
  - Auditing standards require that sufficient, relevant, and reliable evidence is obtained to support audit conclusions and opinions.
  - Audits should be conducted by qualified audit professionals.
  - The audit plan is a high-level description of audit work to be performed in a specific time frame.
  - The plan may include objectives, scope, resource requirements, intended evidence collection techniques, target audience, and reporting expectations.



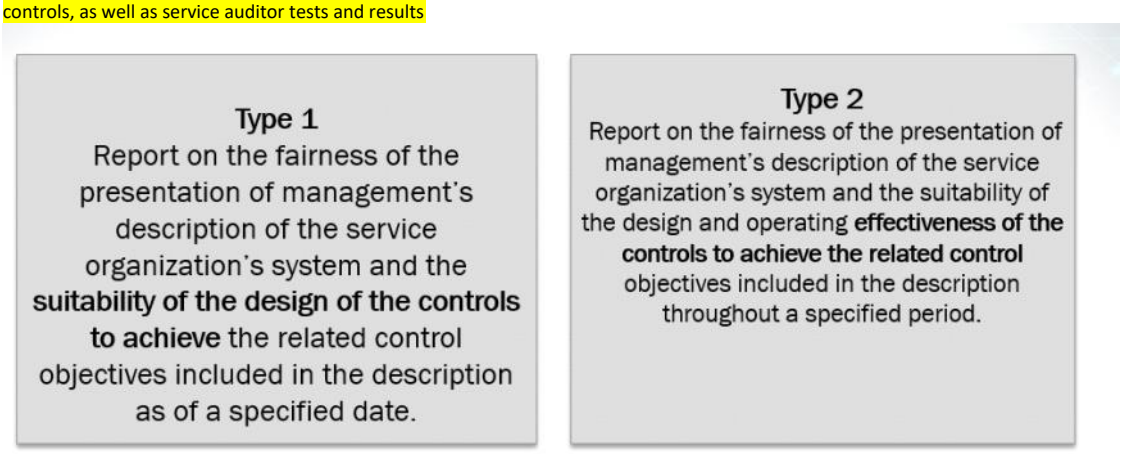
- **Audit Techniques**



- Statement on Auditing Standards (SAS) 70
  - U.S. auditing standards for private companies, nonprofit organizations, federal, state, and local governments.
  - SAS 70 – outdated 2011, based on ISAE 3402
  - AICPA Statement on Standards for Attestation Engagements no. 18 (SSAE18)
  - **AICPA - American Institute of Certified Public Accountants**
    - AICPA discontinued SAS 70 and replaced it with SOC Audits (Service Organization Controls) - American Institute of The AICPA (American Institute of Certified Public Accountants) is the association that develops and scores the Uniform Certified Public Accountants examination. Individuals seeking to qualify for public accountant certification in the United States are required to pass the CPA Examination
  - There are three versions – **SOC1, SOC2 & SOC3 and two types – Type 1 & Type 2**
    - SOC 1
      - Service Organization Control that is relevant for Financial statement, address the internal control relevant to an audit of a service organizational financial statement.
      - Internal Control Over Financial Reporting (ICFR) (auditing the financial statements), Organizations wishing to invest in another organization requests SOC1 reports to understand the financial status.
      - Internal Control Over Financial Reporting (ICFR) (auditing the financial statements), Organizations wishing to invest in another organization requests SOC1 reports to understand the financial status.
      - Focused on financial reporting risks and controls specified by the service provider.
      - Most applicable when the service provider performs financial transaction processing or supports a transaction processing system.
      - Controls relevant to a user entity's financial reporting
      - You provide services that can materially affect your clients' financial data
      - Your clients will use the report to perform an audit of their financial statements
      - Your clients will use the report to comply with the SOX Act or similar regulations
      - Further, SOC 1 reports are often necessary when the user entity is publicly traded and must comply with SOX 404 or similar regulations
    - SOC 2
      - Operational Controls
      - Detailed report for users, their auditors, and specified parties.
      - Focuses on security acceptance, Availability, Confidentially, Processing Integrity, Privacy.
      - Report address the Service Organization Control that are relevant to operation compliance on the IT controls
      - **Based upon Trust Services Principles (TSP) SOC 2, reports on controls intended to mitigate risk related to security, availabi lity,**

processing integrity, confidentiality, and privacy

- You provide services that require the storage and protection of your clients' non-financial data Your clients will use the report to gain confidence in your organization's systems and controls Your clients want a detailed understanding of processing and controls, as well as service auditor tests and results



- Type 1 - design of control
- Type 2 - effectiveness of the implementation of the control in the last 6 months
  - The difference between Type 1 and Type 2 reports lies in the time period upon which they focus. Type 1 reports address the suitability of your control design and implementation at a specific point in time. In contrast, a Type 2 report concentrates on control design and operating effectiveness over a period of time. A Type 2 report therefore enables the user auditor to assess the risk of material misstatement of financial statement assertions affected by your organization.

  - Type 1 report is particularly helpful to service companies as it can make them more competitive. It gives potential customers the assurance that a service organization has passed the said auditing procedure, and that their data is safe if they work with the SOC 2-compliant company.
  - Generation of a SOC 2 Type 1 report is also quick after a service entity completes a readiness assessment. Clients commonly look for this report when shopping for a third-party vendor, especially since the other type of SOC 2 report, Type 2, can take up to a year to be completed.
  - Type 2. It can be said that SOC 2 Type 2 compliance gives a level higher of assurance compared to SOC 2 Type 1. To be able to comply with this requirement, a company should pass a thorough examination of its internal control policies and practices over a particular period of time by an auditor. With SOC 2 Type 2 report, a service firm can send a powerful message to potential customers that it applies the best practices on data security and control systems. Service entities with this compliance stand to bag more contracts from bigger firms.

For questions and more clarity refer SOC Types Coffee Dose Link

Exam Points

Statements	Type of Report
Meeting SOX Compliance Requirement financial Stements	SOC 1 Report
Gain confidence place trust Services organization system Data Center Co-locations, Software as a Service (SaaS) providers, Cloud Service providers, Managed IT Services providers, etc.	SOC 2
Report generally available	SOC 3 Only
financial/custodial services, payroll processing,	SOC 1

HOW TO IDENTIFY THE SOC REPORT THAT IS RIGHT FOR YOU		
Will the report be used by your customers and their auditors to plan and perform an audit or integrated audit of your customer's financial statements?	Yes	SOC 1 Report
Will the report be used by your customers as part of their compliance with the Sarbanes-Oxley Act or similar law or regulation?	Yes	SOC 1 Report
Will the report be used by your customers or stakeholders to gain confidence and place trust in a service organization's systems?	Yes	SOC 2 or 3 Report
Do you need to make the report generally available or seal?	Yes	SOC 3 Report
Do your customers have the need for and ability to understand the details of the processing and controls at a service organization, the tests performed by the service auditor and results of those tests?	Yes	SOC 2 Report
	No	SOC 3 Report

Audit Preparation Phase

- Define Audit Scope and overall project timeline
- Identify existing or required controls
- Perform Readiness Review
- Communicate Prioritized Recommendations
- Hold Working sessions to discuss alternative and Remediation plans
- Verify gaps have been closed
- Determine the most effective audit reporting approach.

Audit Phase

- Provide overall project plan (Scope, Auditor, Date of audit)
- Complete advance data collection before on-site work to accelerate the audit process
- Conduct on-site meetings and testing
- Complete off-site analysis of collected information
- Conduct weekly reporting of project status and any identified issues
- Provide a draft report for management review
- Provide an internal report for management

Audit Principles

- Integrity
- Fair Presentation
- Due Professional Care
- Confidentiality
- Independence
- Use of an evidence-based approach
- Use of Risk-Based Approach

Security Testing Technique	Security Testing Tool
Review	
Network Sniffing	Dsniff, Ettercap, Kismet, Mailsnarf, Msgsnarf, Ntop, Phoss, SinFP, SMB Sniffer, and Wireshark
File Integrity Checking	Autopsy, Foremost, RootkitHunter, and Sleuthkit
Target Identification and Analysis	
Application Security Testing	CIRT Fuzzer, Fuzzer 1.2, NetSed, Paros Proxy, and Peach
Network Discovery	Autonomous System Scanner, Ettercap, Firewalk, Netdiscover, Netenum, Netmask, Nmap, P0f, Tctrace, and Umit
Network Port and Service Identification	Amap, AutoScan, Netdiscover, Nmap, P0f, Umit, and UnicornScan
Vulnerability Scanning	Firewalk, GFI LANguard, Hydra, Metasploit, Nmap, Paros Proxy, Snort, and SuperScan
Wireless Scanning	Airsnarf, Airsnort, BdAddr, Bluesnarfer, Btscanner, FakeAP, GFI LANguard, Kismet, and WifiTAP
Target Vulnerability Validation	
Password Cracking	Hydra, John the Ripper, RainbowCrack, Rcrack, SIPcrack, SIPdump, TFTP-Brute, THC PPTP, VNCrack, and WebCrack
Remote Access Testing	IKEProbe, IKE-Scan, PSK-Crack, and VNC_bypauth
Penetration Testing	Driftnet, Dsniff, Ettercap, Kismet, Metasploit, Nmap, Ntop, SinFP, SMB Sniffer, and Wireshark

	SOC 1 Report	SOC 2 Report	SOC 3 Report
Purpose	Report on your controls relevant to the user entity's financial reporting	Report on your controls relevant to security, availability, processing integrity, confidentiality, and/or privacy	Same as SOC 2
A Good Fit for Your Organization If:	• You provide services that can materially affect your clients' financial reporting • Your clients will use the report to support an audit of their financial statements • Your clients will use the report to comply with SOX 404 or similar regulations	• You provide services that require the storage and protection of your clients' data • Your clients will use the report to gain confidence in your organization's systems and controls • Your clients want a detailed understanding of your processing and controls, as well as service auditor tests and results	• Your clients want to make the report generally available (e.g., for marketing purposes) • Your clients will use the report to gain confidence in your organization's systems and controls • Your clients don't need details regarding your controls or auditor tests and results
Applicable Professional Standard	SSAE No. 18, Attestation Standards: Clarification and Recodification Control Objectives are variable.	AT-C 205, Examination Engagements – Uses TSP 2017 Criteria is prescribed.	Same as SOC 2
Certification? (Yes/No)	No	No	Yes
Types 1 and 2? (Yes/No)	Yes	Yes	No (Type 2 only)
Audience Restricted?	Yes	Yes	No
Audience	Your management, as well as the user entity's financial statement auditors, CFO, CIO, controllers, and compliance officers	Your management, as well as the user entity's CFO, CIO, controllers, compliance officers, vendor management, regulators, other appropriate parties, including prospective users or business partners who have an adequate knowledge and understanding of the service organization's industry.	Any interested party